

Resumen para la dirección

ESTATUS DE LA ENTIDAD

Entidad esencial

Directiva NIS 2 artículo 3, apartado 1, letra c),

(proveedor de redes públicas de comunicaciones electrónicas o de servicios de comunicaciones electrónicas disponibles al público que sea al menos mediana empresa)

GRADO DE PREPARACIÓN

59%

Madurez 2.4 con nivel objetivo 4

OBLIGACIONES FORMALES

8/16

3 no cumplidas, 5 en curso

Próximos plazos legales

- 17/10/2027 (en 376 días) — Primera revisión de la Directiva por la Comisión

Mayores brechas

- Ciberhigiene y formación — madurez 2.0 frente al objetivo 4, prioridad crítico
7. Orientaciones y procedimientos para evaluar la eficacia de las medidas de gestión de riesgos de ciberseguridad [artículo 21, apartado 2, letra f), de la Directiva (UE) 2022/2555] — madurez 2.0 frente al objetivo 4, prioridad crítico
9. Criptografía [artículo 21, apartado 2, letra h), de la Directiva (UE) 2022/2555] — madurez 2.0 frente al objetivo 4, prioridad crítico
2. Política de gestión de riesgos [artículo 21, apartado 2, letra a), de la Directiva (UE) 2022/2555] — madurez 2.2 frente al objetivo 4, prioridad alta
4. Continuidad de las actividades y gestión de las crisis [artículo 21, apartado 2, letra c), de la Directiva (UE) 2022/2555] — madurez 2.2 frente al objetivo 4, prioridad alta

Las autoridades adquieren la facultad de imponer multas a partir del 17/10/2024 (Directiva NIS 2 artículo 41, apartado 1). Desde cuándo puede la autoridad nacional imponer multas lo determina la ley de transposición; este módulo no la conoce. Por eso el riesgo financiero no lleva fecha aquí, mientras que las obligaciones de implantación se derivan del derecho nacional desde su entrada en vigor.

Responsabilidad financiera

Entidad

Cómo se forma este límite: dos pasos distintos

1. El límite mínimo lo fija la Directiva
- Se comparan dos valores: una cuantía fija en euros y un porcentaje del volumen de negocios anual total a escala mundial de la empresa en el ejercicio anterior. El mayor es el límite superior que el Estado miembro debe prever como mínimo. El derecho nacional puede elevarlo.
- Directiva NIS 2 artículo 34, apartado 4 y 5
2. El importe dentro del límite lo fija la autoridad nacional
- La multa debe ser efectiva, proporcionada y disuasoria según las circunstancias de cada caso. La autoridad tiene en cuenta al menos los criterios del artículo 32, apartado 7: gravedad y duración de la infracción, infracciones anteriores, daños, intencionalidad, medidas correctoras y cooperación.
- Directiva NIS 2 artículo 34, apartado 1 y 3
- El límite puede superar varias veces el volumen de negocios anual: es un límite superior, no un importe esperado. Los mínimos nacionales, las multas coercitivas y el procedimiento de graduación los determina la ley del Estado miembro.

El límite legal de la multa asciende a **10.000.000 EUR**. Prevalece la cuantía fija: 10 millones EUR es mayor que el 2 % del volumen de negocios.

- Variante porcentual: 480.000 EUR
- Variante de cuantía fija: 10.000.000 EUR
- Mínimo legal: 0 EUR

Los límites del artículo 34, apartados 4 y 5, son mínimos («al menos»): el derecho nacional puede prever otros mayores. Importes en euros, sin conversión a la moneda nacional.

Graduación de la multa — Directiva NIS 2 artículo 34, apartado 3 y artículo 32, apartado 7

Al decidir si se impone una multa administrativa y su importe, se tienen debidamente en cuenta en cada caso, como mínimo, los elementos enumerados en el artículo 32, apartado 7.

- Criterios del artículo 32, apartado 7, de la Directiva:
- la gravedad de la infracción y la importancia de las disposiciones infringidas; se consideran graves en todo caso: las infracciones reiteradas, la falta de notificación o corrección de incidentes significativos, la falta de subsanación de deficiencias contra instrucciones vinculantes, la obstrucción de auditorías o del seguimiento, y el suministro de información falsa o manifestamente inexacta
 - czas trwania naruszenia
 - cualquier infracción anterior pertinente cometida por la entidad
 - los daños materiales o inmateriales causados, incluidas las pérdidas financieras, la repercusión en otros servicios y el número de usuarios afectados
 - el carácter intencionado o negligente de la infracción
 - las medidas adoptadas para prevenir o mitigar los daños
 - la adhesión a códigos de conducta aprobados o a mecanismos de certificación
 - el grado de cooperación con las autoridades competentes

La Directiva no prevé expresamente la renuncia a la multa; si es posible y cuándo lo decide el derecho nacional.

- Los Estados miembros pueden prever multas coercitivas para obligar a poner fin a una infracción. El importe lo fija el derecho nacional.
- La Directiva no prevé una multa distinta por infracción cualificada; es una construcción del derecho nacional de algunos países.

Directivo de la entidad

Acto jurídico	Base	Autoridad	Límite
Directiva (UE) 2022/2555	Directiva NIS 2 artículo 20, apartado 1	Autoridad competente del Estado miembro	0 EUR

- El órgano de dirección aprueba las medidas de gestión de riesgos de ciberseguridad (artículo 20, apartado 1).
- El órgano de dirección supervisa la implantación de esas medidas (artículo 20, apartado 1).
- Los miembros del órgano de dirección reciben formación periódica (artículo 20, apartado 2).
- Respecto de una entidad esencial, la autoridad puede solicitar la prohibición temporal de ejercer funciones directivas (artículo 32, apartado 5, letra b)).

La entidad ejerce una actividad de comunicaciones electrónicas: la responsabilidad del directivo la determina el derecho nacional

Las autoridades adquieren la facultad de imponer multas a partir del **17/10/2024** (Directiva NIS 2 artículo 41, apartado 1). Desde cuándo puede la autoridad nacional imponer multas lo determina la ley de transposición; este módulo no la conoce. Las obligaciones de implantación se derivan del derecho nacional desde su entrada en vigor.

2.4

Rozwijany

MADUREZ GLOBAL

59%

Objetivo: nivel 4

GRADO DE CUMPLIMIENTO

1.6

hasta el nivel objetivo

BRECHA MEDIA

212/212

100% completado

RESPUESTAS

Perfil de madurez

12 áreas con mayor brecha de 23

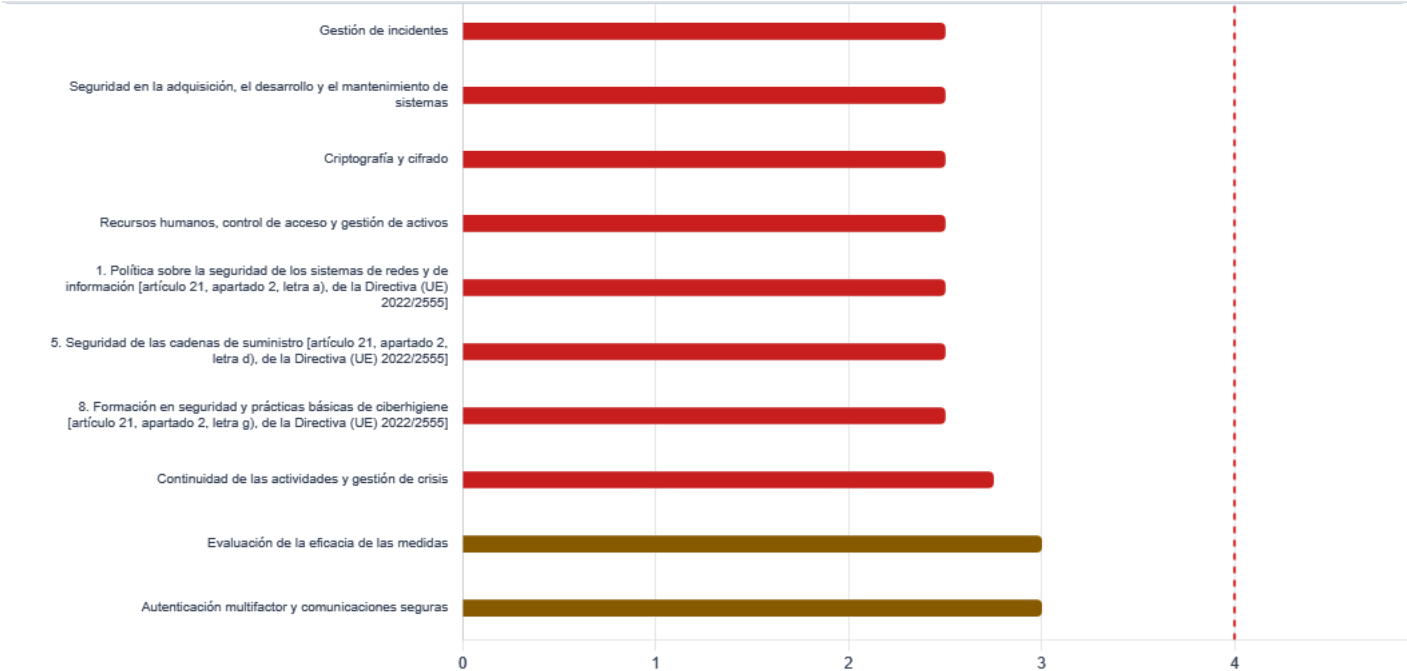


Madurez por áreas



Grado de respuesta por acto jurídico

Acto jurídico	Completado	Madurez
Obligaciones Directiva NIS 2 — obligaciones formales	16/16	—
NIS 2 Directiva NIS 2 — artículo 21	35/35	2.5
2024/2690 Reglamento (UE) 2024/2690	161/161	2.3



Análisis de brechas						
Área		Actual	Objetivo	Brecha	Prioridad	Grado de respuesta
Ciberhigiene y formación		2.0	4	2.0	Crítico	3/3
Directiva NIS 2	artículo 21, apartado 2, letra g)					
Directiva NIS 2	artículo 20, apartado 2					
7. Orientaciones y procedimientos para evaluar la eficacia de las medidas de gestión de riesgos de ciberseguridad [artículo 21, apartado 2, letra f), de la Directiva (UE) 2022/2555]		2.0	4	2.0	Crítico	3/3
Regl. 2024/2690	Anexo, sección 7					
9. Criptografía [artículo 21, apartado 2, letra h), de la Directiva (UE) 2022/2555]		2.0	4	2.0	Crítico	3/3
Regl. 2024/2690	Anexo, sección 9					
2. Política de gestión de riesgos [artículo 21, apartado 2, letra a), de la Directiva (UE) 2022/2555]		2.2	4	1.8	Alta	11/11
Regl. 2024/2690	Anexo, sección 2					
4. Continuidad de las actividades y gestión de las crisis [artículo 21, apartado 2, letra c), de la Directiva (UE) 2022/2555]		2.2	4	1.8	Alta	14/14
Regl. 2024/2690	Anexo, sección 4					
Políticas de análisis de riesgos y seguridad de los sistemas de información		2.3	4	1.8	Alta	4/4
Directiva NIS 2	artículo 21, apartado 2, letra a)					
Seguridad de la cadena de suministro		2.3	4	1.8	Alta	4/4
Directiva NIS 2	artículo 21, apartado 2, letra d)					
Directiva NIS 2	artículo 21, apartado 3					
11. Control de accesos [artículo 21, apartado 2, letras i) y j), de la Directiva (UE) 2022/2555]		2.3	4	1.7	Alta	21/21
Regl. 2024/2690	Anexo, sección 11					
6. Seguridad en la adquisición, el desarrollo y el mantenimiento de sistemas de redes y de información [artículo 21, apartado 2, letra e), de la Directiva (UE) 2022/2555]		2.3	4	1.7	Alta	31/31
Regl. 2024/2690	Anexo, sección 6					
13. Seguridad medioambiental y física [artículo 21, apartado 2, letras c), e) e i), de la Directiva (UE) 2022/2555]		2.3	4	1.7	Alta	9/9
Regl. 2024/2690	Anexo, sección 13					
10. Seguridad de los recursos humanos [artículo 21, apartado 2, letra i), de la Directiva (UE) 2022/2555]		2.4	4	1.6	Alta	10/10
Regl. 2024/2690	Anexo, sección 10					
3. Gestión de incidentes [artículo 21, apartado 2, letra b), de la Directiva (UE) 2022/2555]		2.4	4	1.6	Alta	22/22
Regl. 2024/2690	Anexo, sección 3					
12. Gestión de activos [artículo 21, apartado 2, letra i), de la Directiva (UE) 2022/2555]		2.5	4	1.5	Alta	13/13
Regl. 2024/2690	Anexo, sección 12					
Gestión de incidentes		2.5	4	1.5	Alta	4/4
Directiva NIS 2	artículo 21, apartado 2, letra b)					
Seguridad en la adquisición, el desarrollo y el mantenimiento de sistemas		2.5	4	1.5	Alta	4/4
Directiva NIS 2	artículo 21, apartado 2, letra e)					
Criptografía y cifrado		2.5	4	1.5	Alta	2/2
Directiva NIS 2	artículo 21, apartado 2, letra h)					
Recursos humanos, control de acceso y gestión de activos		2.5	4	1.5	Alta	4/4
Directiva NIS 2	artículo 21, apartado 2, letra i)					
1. Política sobre la seguridad de los sistemas de redes y de información [artículo 21, apartado 2, letra a), de la Directiva (UE) 2022/2555]		2.5	4	1.5	Alta	8/8
Regl. 2024/2690	Anexo, sección 1					
5. Seguridad de las cadenas de suministro [artículo 21, apartado 2, letra d), de la Directiva (UE) 2022/2555]		2.5	4	1.5	Alta	8/8
Regl. 2024/2690	Anexo, sección 5					
8. Formación en seguridad y prácticas básicas de ciberhigiene [artículo 21, apartado 2, letra g), de la Directiva (UE) 2022/2555]		2.5	4	1.5	Alta	8/8
Regl. 2024/2690	Anexo, sección 8					
Continuidad de las actividades y gestión de crisis		2.8	4	1.3	Medio	4/4
Directiva NIS 2	artículo 21, apartado 2, letra c)					

Área	Actual	Objetivo	Brecha	Prioridad	Grado de respuesta
Evaluación de la eficacia de las medidas Directiva NIS 2 artículo 21, apartado 2, letra f)	3.0	4	1.0	Medio	3/3
Autenticación multifactor y comunicaciones seguras Directiva NIS 2 artículo 21, apartado 2, letra j)	3.0	4	1.0	Medio	3/3

Registro de riesgos jurídicos — obligaciones incumplidas			
Obligación	Base	Plazo	Riesgo de sanción
Si la entidad es proveedor de servicios de DNS, registro de TLD, proveedor de nube, centro de datos, CDN, servicios gestionados, mercado en línea, motor de búsqueda o red social, ¿ha presentado los datos adicionales del artículo 27, incluida la dirección de su establecimiento principal en la Unión? Datos de registro para la lista de entidades	Directiva NIS 2 artículo 27, apartado 2	—	artículo 34
Si la entidad es prestador de servicios de confianza, ¿notifica los incidentes significativos en las 24 horas siguientes a tener conocimiento? Notificación de incidentes significativos	Directiva NIS 2 artículo 23, apartado 4, párrafo segundo	24 godzin	artículo 34
¿Está la entidad esencial preparada para una auditoría de seguridad realizada por la autoridad o por un organismo independiente, a su propia costa? Preparación para las actuaciones de supervisión	Directiva NIS 2 artículo 32, apartado 2, letra b–c i), apartado 3	—	artículo 32, apartado 4

Calendario legal			
Fecha	Evento	Base	Restante
16/1/2023	Entrada en vigor de la Directiva NIS 2 A los veinte días de su publicación en el Diario Oficial.	Directiva NIS 2 artículo 45	en vigor
17/10/2024	Plazo de transposición de la Directiva Antes de esta fecha los Estados miembros debían adoptar y publicar las disposiciones nacionales.	Directiva NIS 2 artículo 41, apartado 1	en vigor
18/10/2024	Aplicación de las disposiciones nacionales y derogación de NIS 1 Desde esta fecha los Estados aplican las disposiciones de transposición; la Directiva (UE) 2016/1148 queda derogada.	Directiva NIS 2 artículo 41, apartado 1 y artículo 44	en vigor
7/11/2024	Aplicación del Reglamento (UE) 2024/2690 El Reglamento de Ejecución se aplica directamente a partir de los veinte días de su publicación.	Regl. 2024/2690 artículo 16	en vigor
17/4/2025	Lista de entidades esenciales e importantes Antes de esta fecha los Estados miembros establecen la lista; las entidades presentan sus datos de registro a las autoridades.	Directiva NIS 2 artículo 3, apartado 3 y 4	vencido
17/10/2027	Primera revisión de la Directiva por la Comisión La Comisión revisa el funcionamiento de la Directiva y presenta un informe.	Directiva NIS 2 artículo 40	376 días

Umbrales del incidente significativo

Para las funciones siguientes, los umbrales se derivan directamente del Reglamento (UE) 2024/2690 y se aplican desde el 7 de noviembre de 2024.

Proveedores de servicios de centro de datos (Artículo 8)

El conjunto de umbrales más estricto de todo el Reglamento. Para los centros de datos NO hay umbral de 30 minutos ni umbral del 5 % / 1 millón de usuarios: toda indisponibilidad total del servicio y toda vulneración del acceso físico constituyen un incidente significativo.

- **a)** El servicio de centro de datos no está disponible en absoluto — SIN umbral de tiempo.
- **b)** La disponibilidad del servicio está limitada durante más de 1 hora — SIN umbral porcentual ni de número de usuarios.
- **c)** Se ha comprometido la integridad, la confidencialidad o la autenticidad de los datos a raíz de una acción presuntamente malintencionada.
- **d)** Se ha vulnerado el acceso físico al centro de datos operado por el proveedor.

Criterios horizontales (artículo 3, apartado 1): basta con cumplir uno

- **a)** Pérdida financiera — La pérdida financiera sufrida o posible supera los 500 000 EUR o el 5 % del volumen de negocios anual total de la entidad en el ejercicio anterior, la cifra que sea menor.
- **b)** Fuga de secretos comerciales — El incidente ha causado o puede causar la exfiltración de secretos comerciales en el sentido del artículo 2, punto 1, de la Directiva (UE) 2016/943.
- **c)** Fallecimiento de una persona física — El incidente ha causado o puede causar el fallecimiento de una persona física.
- **d)** Daño considerable a la salud — El incidente ha causado o puede causar un daño considerable a la salud de una persona física.
- **e)** Acceso no autorizado — Se ha producido un acceso no autorizado, logrado y presuntamente malintencionado a las redes y sistemas de información, capaz de causar perturbaciones operativas graves.
- **f)** Incidentes recurrentes — El incidente cumple los criterios del artículo 4: se ha producido al menos dos veces en seis meses, los incidentes tienen la misma causa raíz aparente y en conjunto cumplen el criterio de pérdida financiera del artículo 3, apartado 1, letra a). Se consideran en conjunto un único incidente significativo.
- **g)** Criterio sectorial — El incidente cumple al menos uno de los criterios sectoriales establecidos en los artículos 5 a 14 del Reglamento.

Actividad de comunicaciones electrónicas: los umbrales los fija el derecho nacional. El Reglamento (UE) 2024/2690 no se aplica a los proveedores de redes públicas y servicios de comunicaciones electrónicas. Para ellos, los umbrales del incidente significativo los fija el derecho nacional (artículo 23, apartado 11, de la Directiva); este módulo no los conoce, por lo que no indica cifras.

Historial y progreso

Aún no se ha guardado ninguna instantánea. Una instantánea congela el estado actual de la evaluación junto con la fecha, de modo que los informes posteriores muestran el progreso.

Guardar la primera instantánea